

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN



Môn Học: Thực Tập Cơ Sở
Báo Cáo Thực Hành Bài 6
Cài Đặt Cấu Hình HIDS/NIDS

Giảng viên:	Phạm Hoàng Duy
Sinh viên:	Hoàng Anh Khoa
Mã sinh viên:	B22DCAT164
Hệ đào tạo:	Đại học chính quy

Hà Nội, 2/2025

Mục Lục

1. Mục đích	2
2. Nội dung thực hành	2
2.1 Cơ sở lí thuyết.....	2
2.1.1 Tìm hiểu khái quát về các hệ thống phát hiện tấn công, xâm nhập, phân loại các hệ thống phát hiện xâm nhập, các kỹ thuật phát hiện xâm nhập.....	2
2.1.2. Tìm hiểu về kiến trúc và tính năng của một số hệ thống phát hiện tấn công, xâm nhập: Snort, OSSEC	6
2.1.2.1. Snort	6
2.1.2.2. Ossec	8
2.2. Nội dung thực hành.....	11
2.2.1. Chuẩn bị môi trường	11
2.2.2. Các bước thực hiện	11
3. Kết luận	18
4. Tài liệu tham khảo	18

Môn học: INT13147 - Thực tập cơ sở

Bài thực hành số 6 - Cài đặt cấu hình HIDS/NIDS

1. Mục đích

- Luyện tập việc cài đặt và vận hành các hệ thống phát hiện xâm nhập cho host (HIDS) và cho mạng (NIDS).
- Luyện tập việc tạo và chỉnh sửa các luật phát hiện tấn công, xâm nhập cho các hệ thống phát hiện xâm nhập thông dụng.

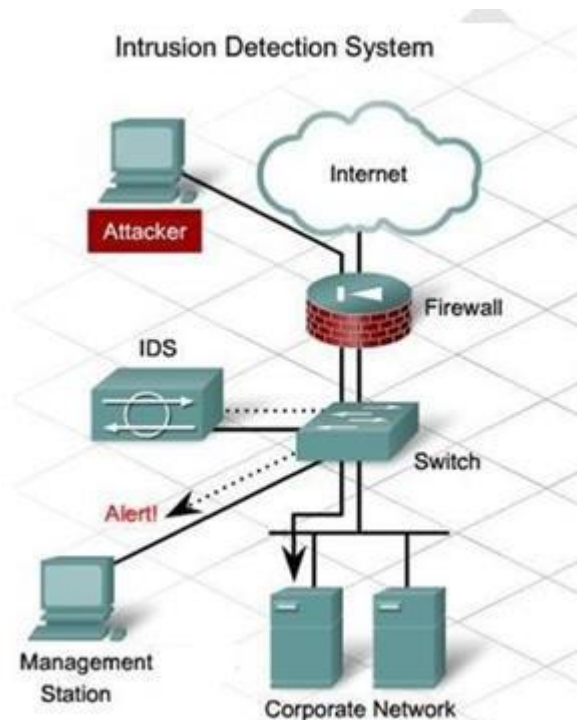
2. Nội dung thực hành

2.1 Cơ sở lý thuyết

2.1.1 Tìm hiểu khái quát về các hệ thống phát hiện tấn công, xâm nhập, phân loại các hệ thống phát hiện xâm nhập, các kỹ thuật phát hiện xâm nhập.

a. Giới thiệu về hệ thống phát hiện tấn công, xâm nhập

Các hệ thống phát hiện tấn công, xâm nhập (IDS – Intrusion Detection System) là một lớp phòng vệ quan trọng trong các lớp giải pháp đảm bảo an toàn cho hệ thống thông tin và mạng theo mô hình phòng thủ có chiều sâu (defence in depth). Các hệ thống IDS có thể được đặt trước hoặc sau tường lửa trong mô hình mạng tùy theo mục đích sử dụng. IDS thường được kết nối vào bộ chuyển mạch (switch) phía sau tường lửa



Nhiệm vụ chính của các hệ thống IDS bao gồm:

- Giám sát lưu lượng mạng hoặc các hành vi trên một hệ thống để nhận dạng các dấu hiệu của tấn công, xâm nhập;
- Khi phát hiện các hành vi tấn công, xâm nhập, thì ghi logs các hành vi này cho phân tích bổ sung sau này;
- Gửi thông báo cho người quản trị về các hành vi tấn công, xâm nhập đã phát hiện được.

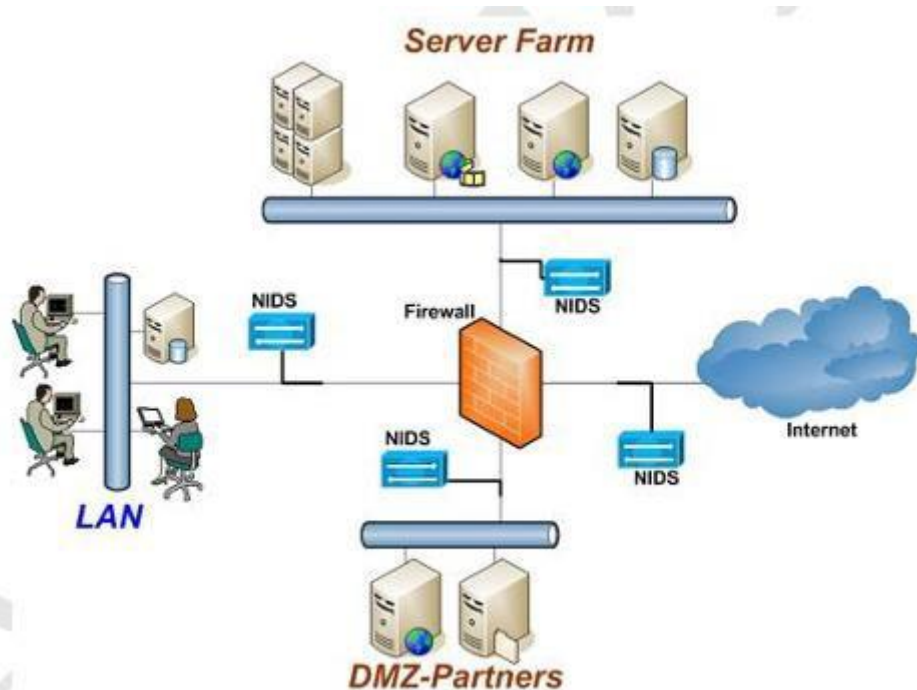
Nói tóm lại, IDS thường được kết nối vào các bộ định tuyến, switch, card mạng và chủ yếu làm nhiệm vụ giám sát và cảnh báo, không có khả năng chủ động ngăn chặn tấn công, xâm nhập.

b. Phân loại hệ thống phát hiện tấn công, xâm nhập

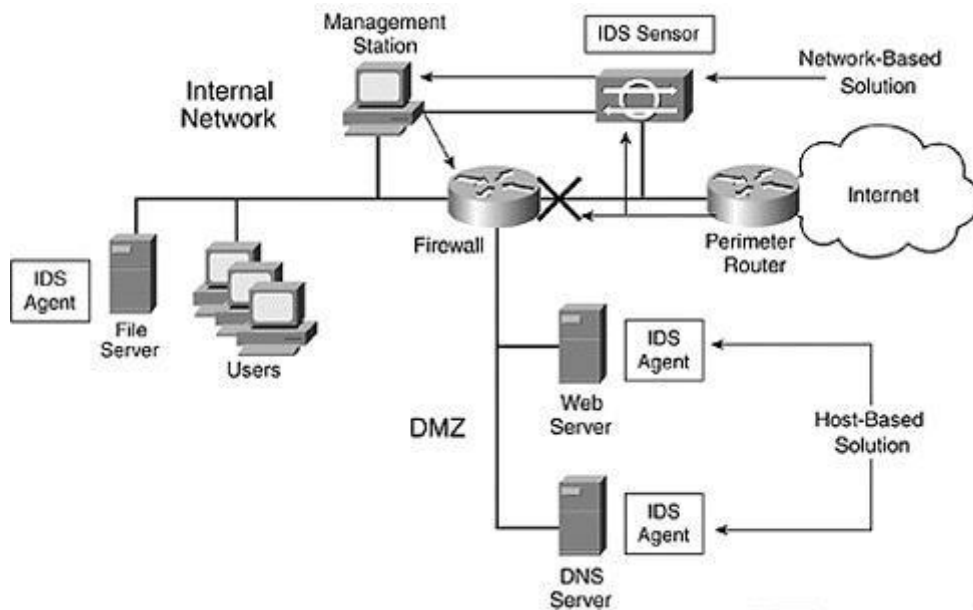
Có 2 phương pháp phân loại chính các hệ thống IDS gồm (1) phân loại theo nguồn dữ liệu và (2) phân loại theo phương pháp phân tích dữ liệu.

Theo nguồn dữ liệu, có 2 loại hệ thống phát hiện xâm nhập:

- Hệ thống phát hiện xâm nhập mạng (NIDS – Network-based IDS): NIDS phân tích lưu lượng mạng để phát hiện tấn công, xâm nhập cho cả mạng hoặc một phần mạng. Hình dưới đây biểu diễn một sơ đồ mạng, trong đó các NIDS được bố trí để giám sát phát hiện xâm nhập tại cổng vào và cho từng phân đoạn mạng.



- Hệ thống phát hiện xâm nhập cho host (HIDS – Host-based IDS): HIDS phân tích các sự kiện xảy ra trong hệ thống/dịch vụ để phát hiện tấn công, xâm nhập cho hệ thống đó. Hình dưới đây minh họa một sơ đồ mạng, trong đó sử dụng NIDS để giám sát lưu lượng tại cổng mạng và HIDS để giám sát các host thông qua các IDS agent. Một trạm quản lý (Management station) được thiết lập để thu nhập các thông tin từ các NIDS và HIDS để xử lý và đưa ra quyết định cuối cùng.



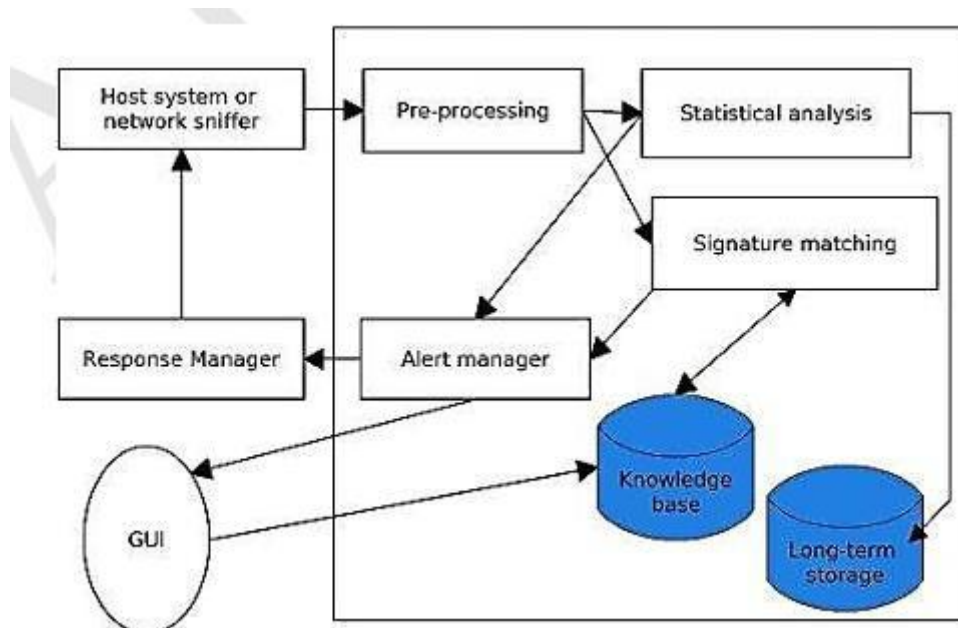
Theo phương pháp phân tích dữ liệu, có 2 kỹ thuật phân tích chính, gồm:

- Phát hiện xâm nhập dựa trên chữ ký, hoặc phát hiện sự lạm dụng (Signature-based / misuse intrusion detection)
- Phát hiện xâm nhập dựa trên các bất thường (Anomaly intrusion detection).

c. Các kỹ thuật phát hiện xâm nhập

a. Phát hiện xâm nhập dựa trên chữ ký

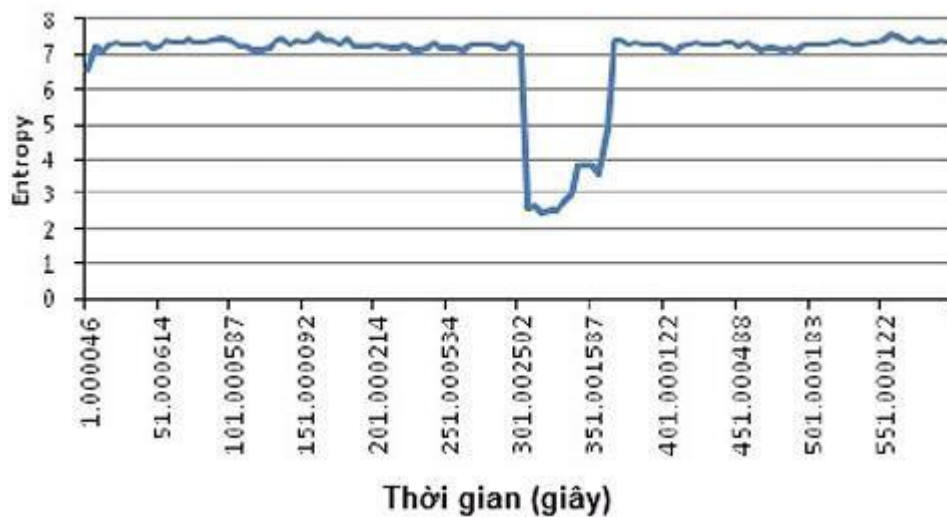
Phát hiện xâm nhập dựa trên chữ ký trước hết cần xây dựng cơ sở dữ liệu các chữ ký, hoặc các dấu hiệu của các loại tấn công, xâm nhập đã biết. Hầu hết các chữ ký, dấu hiệu được nhận dạng và mã hóa thủ công và dạng biểu diễn thường gặp là các luật phát hiện (Detection rule). Bước tiếp theo là sử dụng cơ sở dữ liệu các chữ ký để giám sát các hành vi của hệ thống, hoặc mạng, và cảnh báo nếu phát hiện chữ ký của tấn công, xâm nhập. Hình dưới đây biểu diễn lưu đồ giám sát phát hiện tấn công, xâm nhập dựa trên chữ ký điển hình, trong đó Knowledge base là cơ sở dữ liệu lưu các chữ ký tấn công, xâm nhập.



Ưu điểm lớn nhất của phát hiện xâm nhập dựa trên chữ ký là có khả năng phát hiện các tấn công, xâm nhập đã biết một cách hiệu quả. Ngoài ra, phương pháp này cho tốc độ xử lý cao, đồng thời yêu cầu tài nguyên tính toán tương đối thấp. Nhờ vậy, các hệ thống phát hiện xâm nhập dựa trên chữ ký được ứng dụng rộng rãi trong thực tế. Tuy nhiên, nhược điểm chính của phương pháp này là không có khả năng phát hiện các tấn công, xâm nhập mới, do chữ ký của chúng chưa tồn tại trong cơ sở dữ liệu các chữ ký. Hơn nữa, phương pháp này cũng đòi hỏi nhiều công sức xây dựng và cập nhật cơ sở dữ liệu chữ ký, dấu hiệu của các tấn công, xâm nhập.

b. Phát hiện xâm nhập dựa trên bất thường

Phát hiện xâm nhập dựa trên bất thường dựa trên giả thiết: các hành vi tấn công, xâm nhập thường có quan hệ chặt chẽ với các hành vi bất thường. Quá trình xây dựng và triển khai một hệ thống phát hiện xâm nhập dựa trên bất thường thường gồm 2 giai đoạn: (1) huấn luyện và (2) phát hiện. Trong giai đoạn huấn luyện, hồ sơ (profile) của đối tượng trong chế độ làm việc bình thường được xây dựng. Để thực hiện giai đoạn huấn luyện, cần giám sát đối tượng trong một khoảng thời gian đủ dài để thu thập được đầy đủ dữ liệu mô tả các hành vi của đối tượng trong điều kiện bình thường làm dữ liệu huấn luyện. Tiếp theo, thực hiện huấn luyện dữ liệu để xây dựng mô hình phát hiện, hay hồ sơ của đối tượng. Trong giai đoạn phát hiện, thực hiện giám sát hành vi hiện tại của hệ thống và cảnh báo nếu có khác biệt rõ nét giữa hành vi hiện tại và các hành vi lưu trong hồ sơ của đối tượng.



Hình trên biểu diễn giá trị entropy của IP nguồn của các gói tin theo cửa sổ trượt từ lưu lượng bình thường và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS. Có thể thấy sự khác biệt rõ nét giữa giá trị entropy của lưu lượng bình thường và lưu lượng tấn công và như vậy nếu một ngưỡng entropy được chọn phù hợp ta hoàn toàn có thể phát hiện sự xuất hiện của cuộc tấn công DDoS dựa trên sự thay đổi đột biến của giá trị entropy. Ưu điểm của phát hiện xâm nhập dựa trên bất thường là có tiềm năng phát hiện các loại tấn công, xâm nhập mới mà không yêu cầu biết trước thông tin về chúng. Tuy nhiên, phương pháp này thường có tỷ lệ cảnh báo sai tương đối cao so với phương pháp phát hiện dựa trên chữ ký. Điều này làm giảm khả năng ứng dụng thực tế của phát hiện xâm nhập dựa trên bất thường. Ngoài ra, phương pháp này cũng tiêu tốn nhiều tài nguyên hệ thống cho việc xây dựng hồ sơ đối tượng và phân tích hành vi hiện tại.

2.1.2. Tìm hiểu về kiến trúc và tính năng của một số hệ thống phát hiện tấn công, xâm nhập: Snort, OSSEC

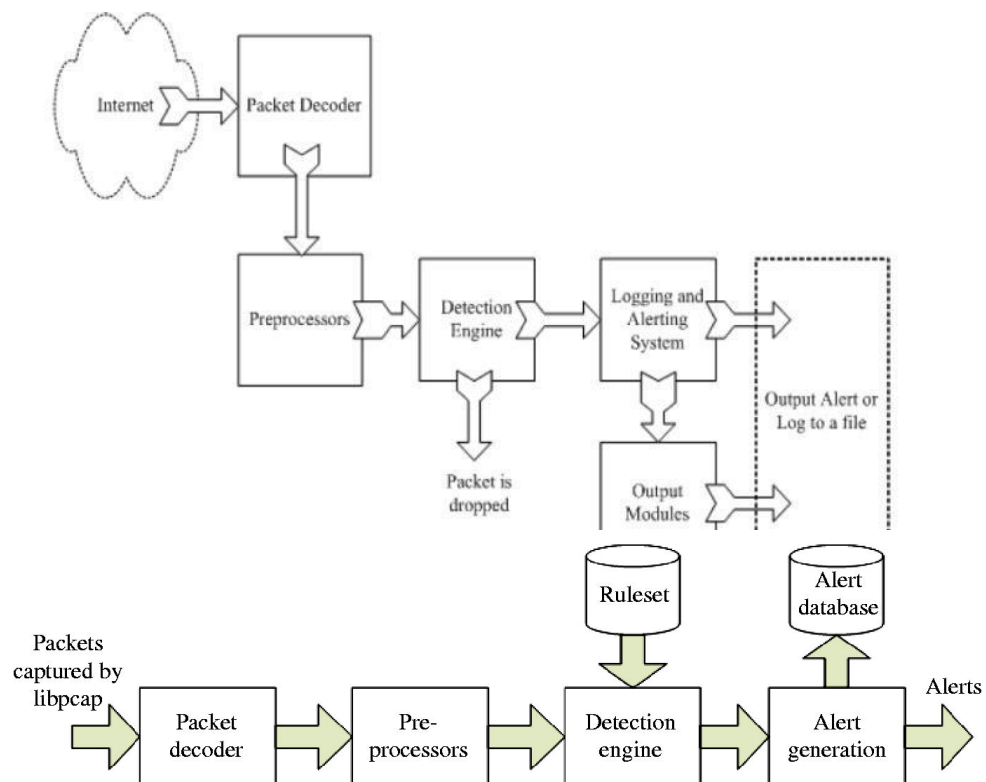
2.1.2.1. Snort

a. Giới thiệu

Snort là một công cụ IDS/IPS, thực hiện giám sát các gói tin ra vào hệ thống.

- Snort là một mã nguồn mở miễn phí với nhiều tính năng trong việc bảo vệ hệ thống bên trong, phát hiện sự tấn công từ bên ngoài vào hệ thống.
- Snort được viết bởi Martin Roesch vào năm 1998. Hiện tại, Snort được phát triển bởi Sourcefire, nơi mà Roesch đang là người sáng lập và CTO, và được sở hữu bởi Cisco từ năm 2013.

b. Kiến trúc của Snort



Trong mô hình kiến trúc trên, hệ thống Snort được chia thành 4 phần:

- Module Decoder: Xử lý giải mã các gói tin
- Module Preprocessors: Tiền xử lý
- Module Detection Engine: Phát hiện
- Module Logging and Alerting System: Lưu log và cảnh báo

c. Các luật của Snort

Cấu trúc của một rule được chia thành 02 phần: **[Rule header|Rule Option]**

- Phần Header: Chứa thông tin về hành động mà luật đó sẽ thực hiện khi phát hiện ra có xâm nhập nằm trong gói tin và nó cũng chứa tiêu chuẩn để áp dụng luật với gói tin đó.
- Phần Option: Chứa thông điệp cảnh báo và các thông tin về các phần của gói tin dùng để tạo nên cảnh báo. Phần Option này chứa các tiêu chuẩn phụ thêm để đối sánh với gói tin

Cấu trúc phần Header: **[Action|Protocol|Address|port|Direction|Address|Port|**

- Action: Thể hiện hành động sẽ được thực hiện khi một gói tin kích hoạt quy tắc. Trong đó:
 - + alert: Tạo một cảnh báo và ghi lại gói tin.
 - + log: Chỉ ghi lại gói tin mà không tạo cảnh báo.
 - + pass: Bỏ qua gói tin, không thực hiện hành động nào.
 - + activate: Tạo ra cảnh báo và kích hoạt thêm các luật khác để kiểm tra thêm điều kiện của gói tin

+ dynamic: Đây là luật được gọi bởi các luật khác có Action khai báo là Activate

- Protocol: Xác định loại giao thức của gói tin, ví dụ: TCP, UDP, ICMP, hoặc any (tất cả).
- Source IP Address: Địa chỉ IP nguồn của gói tin.
- Source Port: Cổng nguồn của gói tin. Có thể là một số cụ thể hoặc từ khoảng cụ thể.
- Direction Operator: Thể hiện hướng của gói tin. Có thể là -> (nguồn tới đích) hoặc <- (đích tới nguồn).
- Destination IP Address: Địa chỉ IP đích của gói tin.
- Destination Port: Cổng đích của gói tin. Cũng có thể là một số cụ thể hoặc từ khoảng cụ thể.

Cấu trúc phần Option:

Phần Option nằm ngay sau phần Header và được bao bọc trong dấu ngoặc đơn. Nếu có nhiều Option thì sẽ phân biệt bởi dấu chấm phẩy ";". Một Option gồm có 2 phần: một là từ khóa và một là tham số. 02 phần này sẽ phân cách nhau bằng dấu hai chấm ":"

Các option có thể là: **msg** (tin nhắn cảnh báo), **content** (nội dung gói tin), **sid** (số nhận dạng duy nhất), **rev** (số phiên bản quy tắc), **content:** Chứa một chuỗi hoặc byte pattern để so khớp với dữ liệu gói tin ...

Ví dụ về cấu trúc một quy tắc Snort:

```
alert tcp any any -> any 80 (msg:"Potential Web Attack"; content:"/bin/bash";  
sid:100001;)
```

2.1.2.2. Ossec

a. Ossec là gì?

OSSEC là phần mềm mã nguồn mở giúp phát hiện xâm nhập dựa trên host (HIDS) Nó đa nền tảng, có thể mở rộng và có nhiều cơ chế bảo mật khác nhau.

b. Các tính năng của Ossec

- Log based Intrusion Detection (LIDs) and Log Monitoring:
 - + Chủ động theo dõi và phân tích dữ liệu real-time từ nhiều nguồn sinh log.
 - + Ngoài ra, Ossec sẽ thu thập, phân tích và kiểm tra mối tương quan các log và cho ta biết những điều đáng ngờ đang xảy ra trong hệ thống (bị tấn công, lỗi, sử dụng sai,...), các phần mềm được cài đặt thêm, các rule firewall bị đổi.
- Compliance Auditing:
 - + Kiểm soát các ứng dụng và hệ thống nhằm tuân thủ các yêu cầu, tiêu

chuẩn về bảo mật như PCI-DSS và CIS.

- Rootkit and Malware Detection:
 - + Tin tặc thường muốn che dấu hành động và quay lại hệ thống đã xâm nhập được
 - + Ossec phân tích ở cấp độ file và tiến trình nhằm phát hiện các ứng dụng độc hại, các rootkit hay các file hệ thống bị sửa đổi theo cách phổ biến với rootkit
- File Integrity Monitoring (FIM):
 - + Phát hiện các thay đổi đối với hệ thống.
- Active Response:
 - + Các hành vi ứng phó lại các cuộc tấn công vào hệ thống trong thời gian thực.
 - + Giúp ngăn sự cố lan rộng trước khi admin có thể hành động
- System Inventory:
 - + Thu thập các thông tin hệ thống như phần mềm được cài đặt, hardware,...

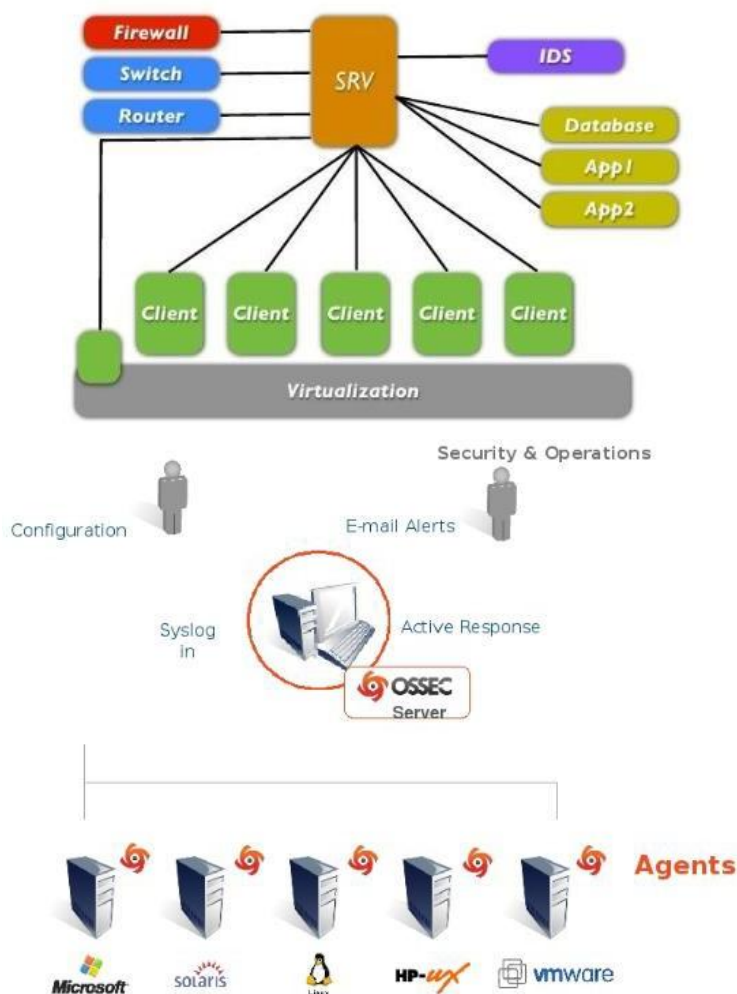
c. Điểm nổi trội của Ossec

- Đa nền tảng (Linux, Mac OS, Window, Solaris)
- Real-time Alert (Cảnh báo thời gian thực)
 - + Kết hợp với smtp, sms, syslog sẽ cho phép người dùng nhận cảnh báo trên các thiết bị có hỗ trợ email
 - + Ngoài ra tính năng Active-response có thể giúp block 1 cuộc tấn công ngay lập tức.
- Có thể tích hợp với các hệ thống hiện đại (SIM/SEM)
- Mô hình Server – Agent/Agentless, cho phép Server dễ dàng quản lý tập trung các chính sách trên nhiều OS.
- Giám sát trên agent, agentless (Client không cài đặt được gói agent) như router, firewall

d. Kiến trúc và mô hình hoạt động của Ossec

Ossec hoạt động theo mô hình Server-Agent/Agentless

OSSEC Architecture



❖ Manager (Server)

Lưu trữ cơ sở dữ liệu của việc kiểm tra tính toàn

vẹn file Kiểm tra các log, event.

Quản lý, lưu tất cả các rule, decoder (bộ giải mã), cấu hình chính. Điều này giúp dễ dàng quản lý, dù cho có lượng lớn Agent

Server không chạy trên Windows OS.

❖ Agent

Bản chất thì là 1 phần mềm được cài đặt trên máy client giúp thu thập các thông tin và gửi cho Server để phân tích, thống kê.

- Chiếm lượng memory và CPU nhỏ, không đáng kể
- 1 số thông tin được thu thập theo thời gian thực
- 1 số thông tin thì lại được thu thập định kỳ

- Nhưng khi nói Agent thì là để chỉ máy Client được cài gói Ossec-agent.

Chú ý: Windows OS chỉ có thể làm Agent chứ không làm Server được.

❖ **Agentless**

Là các hệ thống không cài được gói agent

Trên các Agentless này có thể thực hiện việc kiểm tra

tính toàn vẹn Giúp monitor firewall, router hay thậm

chí cả hệ thống Unix

❖ **Ảo hóa/ VMware**

Cho phép cài đặt agent trên các guest OS (Máy ảo)

Ngoài ra cũng được cài đặt trong VMware ESX nhưng có thể dẫn đến sự cố không hỗ trợ.

Khi cài đặt trong VMware ESX giúp nhận được thời điểm các VM guest được khởi tạo, xóa đi, khởi động,... Ossec cũng giám sát việc login, logouts và các lỗi bên trong ESX server

Ngoài ra nó cũng cảnh báo nếu bất kỳ tùy chọn cấu hình không an toàn nào được bật.

❖ **Firewalls, switches and routers**

Chính là các Agentless

Ossec có thể nhận và phân tích nhật ký hệ thống từ nhiều firewall, switch, router.

Nó support tất cả Cisco routers, Cisco PIX, Cisco FWSM, Cisco ASA, Juniper Routers, Netscreen firewall, Checkpoint và nhiều thiết bị khác.

2.2. Nội dung thực hành

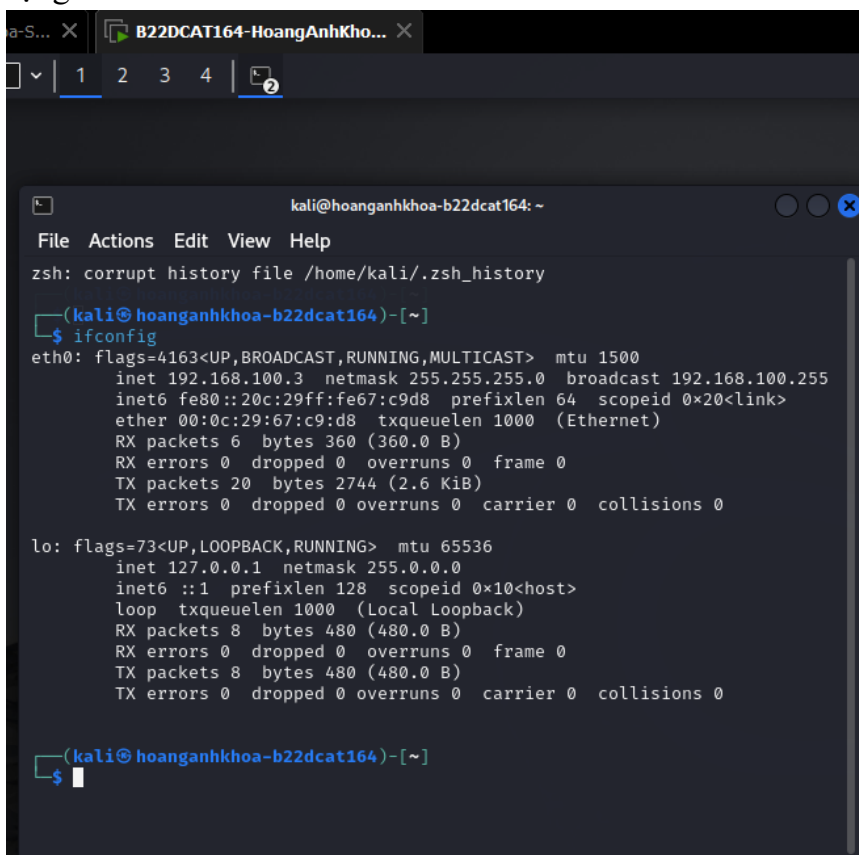
2.2.1. Chuẩn bị môi trường

- 01 máy tính (máy thật hoặc máy ảo) chạy Linux với RAM tối thiểu 2GB, 10GB đĩa cứng có kết nối mạng (LAN hoặc Internet).
- 01 máy tính (máy thật hoặc máy ảo) chạy Kali Linux (bản 2021 trở lên)
- Bộ phần mềm Snort tải tại <https://www.snort.org/download>

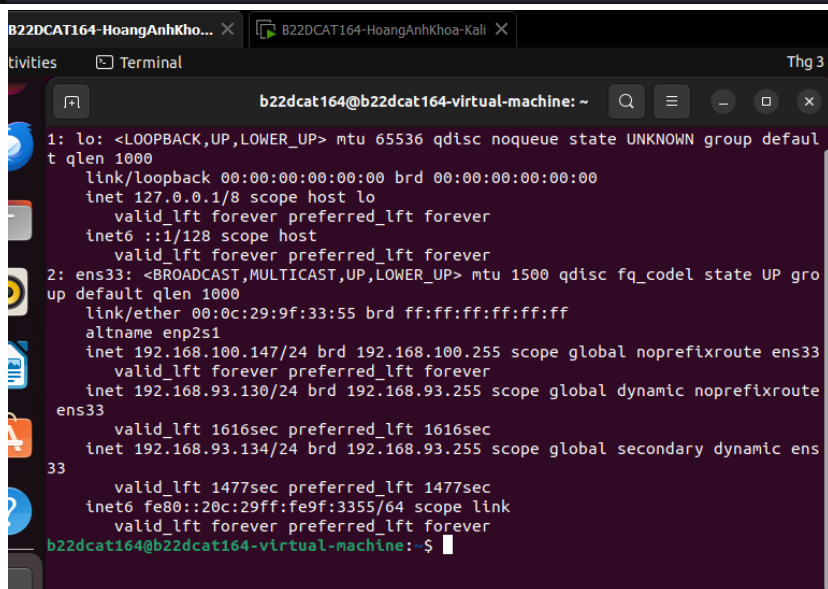
2.2.2. Các bước thực hiện

a. Bước 1: Chuẩn bị các máy tính như mô tả trong mục 2.2.1 Máy Kali Linux

được đổi tên thành B22DCAT151-HoangAnhKhoa-Kali và máy cài Snort thành B22DCAT164-HoangAnhKhoa-Snort. Các máy có địa chỉ IP và kết nối mạng LAN.



```
kali@hoanganhkhoa-b22dcat164: ~  
File Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
  
(kali@hoanganhkhoa-b22dcat164)-[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.100.3 netmask 255.255.255.0 broadcast 192.168.100.255  
    inet6 fe80::20c:29ff:fe67:c9d8 prefixlen 64 scopeid 0x20<link>  
    ether 00:0c:29:67:c9:d8 txqueuelen 1000 (Ethernet)  
    RX packets 6 bytes 360 (360.0 B)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 20 bytes 2744 (2.6 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 8 bytes 480 (480.0 B)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 8 bytes 480 (480.0 B)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
(kali@hoanganhkhoa-b22dcat164)-[~]  
$
```



```
b22dcat164@b22dcat164-virtual-machine: ~  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group  
    link/ether 00:0c:29:9f:33:55 brd ff:ff:ff:ff:ff:ff  
    altname enp2s1  
    inet 192.168.100.147/24 brd 192.168.100.255 scope global noprefixroute ens33  
        valid_lft forever preferred_lft forever  
    inet 192.168.93.130/24 brd 192.168.93.255 scope global dynamic noprefixroute  
        valid_lft 1616sec preferred_lft 1616sec  
    inet 192.168.93.134/24 brd 192.168.93.255 scope global secondary dynamic ens33  
        valid_lft 1477sec preferred_lft 1477sec  
    inet6 fe80::20c:29ff:fe9f:3355/64 scope link  
        valid_lft forever preferred_lft forever  
b22dcat164@b22dcat164-virtual-machine: $
```

b. Bước 2: Tải, cài đặt Snort và chạy thử Snort. Kiểm tra log của Snort để đảm bảo Snort hoạt động bình thường.

- Tải snort:
 - + sudo apt update
 - + sudo apt install snort
- Kiểm tra phiên bản của snort

```

valid_lft forever preferred_lft forever
b22dcat164@b22dcat164-virtual-machine:~$ snort --version

-*> Snort! <*-
o" )~
' ' '
ved.

Version 2.9.15.1 GRE (Build 15125)
By Martin Roesch & The Snort Team: http://www.snort.org/contact#team
Copyright (C) 2014-2019 Cisco and/or its affiliates. All rights reserved.

Copyright (C) 1998-2013 Sourcefire, Inc., et al.
Using libpcap version 1.10.1 (with TPACKET_V3)
Using PCRE version: 8.39 2016-06-14
Using ZLIB version: 1.2.11

b22dcat164@b22dcat164-virtual-machine:~$

```

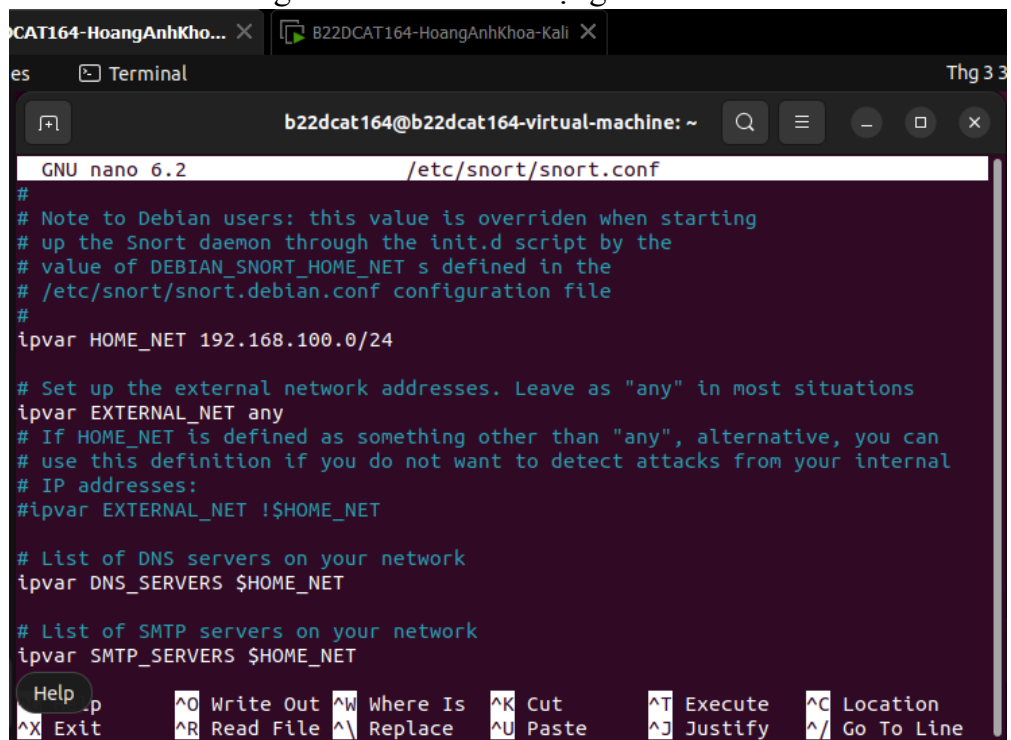
- Kiểm tra trạng thái của snort

```

b22dcat164@b22dcat164-virtual-machine:~$ sudo nmap -sP 192.168.100.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-03-03 11:56 +07
Nmap scan report for 192.168.100.3
Host is up (0.00025s latency).
MAC Address: 00:0C:29:67:C9:D8 (VMware)
Nmap scan report for b22dcat164-virtual-machine (192.168.100.147)
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 1.98 seconds
b22dcat164@b22dcat164-virtual-machine:~$

```

- Cấu hình snort và giám sát trên card mạng ens33



```

GNU nano 6.2 /etc/snort/snort.conf
#
# Note to Debian users: this value is overridden when starting
# up the Snort daemon through the init.d script by the
# value of DEBIAN_SNORT_HOME_NET s defined in the
# /etc/snort/snort.debian.conf configuration file
#
ipvar HOME_NET 192.168.100.0/24

# Set up the external network addresses. Leave as "any" in most situations
ipvar EXTERNAL_NET any
# If HOME_NET is defined as something other than "any", alternative, you can
# use this definition if you do not want to detect attacks from your internal
# IP addresses:
#ipvar EXTERNAL_NET !$HOME_NET

# List of DNS servers on your network
ipvar DNS_SERVERS $HOME_NET

# List of SMTP servers on your network
ipvar SMTP_SERVERS $HOME_NET

Help      ^O Write Out  ^W Where Is  ^K Cut        ^T Execute   ^C Location
^X Exit    ^R Read File  ^\ Replace  ^U Paste     ^J Justify   ^_ Go To Line

```

- Kiểm tra cấu hình snort: `sudo -T -i ens33 -c /etc/snort/snort.conf`

```
b22dcat164@b22dcat164-virtual-machine: ~  
Using libpcap version 1.10.1 (with TPACKET_V3)  
Using PCRE version: 8.39 2016-06-14  
Using ZLIB version: 1.2.11  
  
Rules Engine: SF_SNORT_DETECTION_ENGINE Version 3.1 <Build 1>  
Preprocessor Object: SF_GTP Version 1.1 <Build 1>  
Preprocessor Object: SF_SSLPP Version 1.1 <Build 4>  
Preprocessor Object: SF_IMAP Version 1.0 <Build 1>  
Preprocessor Object: SF_POP Version 1.0 <Build 1>  
Preprocessor Object: SF_SSH Version 1.1 <Build 3>  
Preprocessor Object: appid Version 1.1 <Build 5>  
Preprocessor Object: SF_REPUTATION Version 1.1 <Build 1>  
Preprocessor Object: SF_SIP Version 1.1 <Build 1>  
Preprocessor Object: SF_SMTP Version 1.1 <Build 9>  
Preprocessor Object: SF_SDF Version 1.1 <Build 1>  
Preprocessor Object: SF_FTPTELNET Version 1.2 <Build 13>  
Preprocessor Object: SF_DNS Version 1.1 <Build 4>  
Preprocessor Object: SF_DNP3 Version 1.1 <Build 1>  
Preprocessor Object: SF_DCERPC2 Version 1.0 <Build 3>  
Preprocessor Object: SF_MODBUS Version 1.1 <Build 1>  
  
Snort successfully validated the configuration!  
Snort exiting  
b22dcat164@b22dcat164-virtual-machine:~$
```

- Khởi chạy giám sát (hiển thị thông báo):

sudo snort -A console -q -c /etc/snort/snort.conf -i ens33

```
/snort.conf -i ens37  
03/05-09:20:55.208331  [**] [1:1917:6] SCAN UPnP service discover attempt [**] [Classification: Detection of a Network Scan] [Priority: 3] {UDP} 192.168.17.1:54624 -> 239.255.255.250:1900  
03/05-09:20:56.216099  [**] [1:1917:6] SCAN UPnP service discover attempt [**] [Classification: Detection of a Network Scan] [Priority: 3] {UDP} 192.168.17.1:54624 -> 239.255.255.250:1900  
03/05-09:20:57.218616  [**] [1:1917:6] SCAN UPnP service discover attempt [**] [Classification: Detection of a Network Scan] [Priority: 3] {UDP} 192.168.17.1:54624 -> 239.255.255.250:1900  
03/05-09:20:58.233141  [**] [1:1917:6] SCAN UPnP service discover attempt [**] [Classification: Detection of a Network Scan] [Priority: 3] {UDP} 192.168.17.1:54624 -> 239.255.255.250:1900
```

c. Bước 3: Tạo các luật Snort để phát hiện 3 dạng rà quét, tấn công hệ thống

```
b22dcat164@b22dcat164-virtual-machine: ~  
local.rules  
/etc/snort/rules  
Save  
1 # $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $  
2 # -----  
3 # LOCAL RULES  
4 # -----  
5 # This file intentionally does not come with signatures. Put your local  
6 # additions here.  
7  
8 alert icmp any any -> $HOME_NET any (msg:"B22DCAT164-HoangAnhKhoa-Snort phát hiện có các gói Ping gửi đến."; icode:0; itype:8; sid:1000001; rev:1;)  
9  
10 alert icmp any any -> $HOME_NET any (msg:"B22DCAT164-HoangAnhKhoa-Snort phát hiện có các gói Ping gửi đến."; icode:0; itype:8; sid:1000002; rev:1;)  
11  
12 alert tcp any any -> $HOME_NET 80 (msg:"B22DCAT164-HoangAnhKhoa-Snort phát hiện có các gói tin rà quét trên cổng 80."; flags:S; sid:1000003; rev:1;)
```

- Yêu cầu:

- + Phát hiện các gói tin ping từ bất kỳ một máy nào gửi đến máy chạy Snort. Hiển thị thông điệp khi phát hiện: “B22DCAT164-HoangAnhKhoa-Snort phát hiện có các gói Ping gửi đến.”
- + Phát hiện các gói tin rà quét từ bất kỳ một máy nào gửi đến máy chạy Snort trên cổng 80. Hiển thị thông điệp khi phát hiện: “B22DCAT164-HoangAnhKhoa-Snort phát hiện có các gói tin rà quét trên cổng 80.”

- + Phát hiện tấn công TCP SYN Flood từ bất kỳ một máy nào gửi đến máy chạy Snort. Hiện thị thông điệp khi phát hiện: “B22DCAT164-HoangAnhKhoa- Snort phát hiện đang bị tấn công TCP SYN Flood.”
- Mở file để tạo thêm luật: *sudo gedit /etc/snort/rules/local.rules*

d. Bước 4: Thực thi tấn công và phát hiện sử dụng Snort.

- Từ máy Kali, sử dụng lệnh ping để ping máy Snort. Trên máy Snort kiểm tra kết quả phát hiện trên giao diện terminal hoặc log của Snort.

```

b22dcat164@b22dcat164-virtual-machine: ~
t qlen 1000
link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
inet 127.0.0.1/8 scope host lo
    valid_lft forever preferred_lft forever
inet6 ::1/128 scope host
    valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
link/ether 00:0c:29:9f:33:55 brd ff:ff:ff:ff:ff:ff
altname enp2s1
inet 192.168.100.147/24 brd 192.168.100.255 scope global noprefixroute ens33
    valid_lft forever preferred_lft forever
inet 192.168.1.21/24 brd 192.168.1.255 scope global dynamic noprefixroute ens33
    valid_lft 86392sec preferred_lft 86392sec
inet6 2405:4802:1c66:bec0:1579:5e52:de88:df26/64 scope global temporary dynamic
    valid_lft 7195sec preferred_lft 3595sec
inet6 2405:4802:1c66:bec0:20c:29ff:fe9f:3355/64 scope global dynamic mngtmpaddr
    valid_lft 7195sec preferred_lft 3595sec
inet6 fe80::20c:29ff:fe9f:3355/64 scope link
    valid_lft forever preferred_lft forever
b22dcat164@b22dcat164-virtual-machine:~$

```

Kiểm tra địa chỉ IP máy Snort

```

(kali@hoanganhkhoa-b22dcat164)-[~]
$ ping 192.168.100.147
PING 192.168.100.147 (192.168.100.147) 56(84) bytes of data:
64 bytes from 192.168.100.147: icmp_seq=1 ttl=64 time=0.835 ms
64 bytes from 192.168.100.147: icmp_seq=2 ttl=64 time=0.462 ms
64 bytes from 192.168.100.147: icmp_seq=3 ttl=64 time=0.524 ms
64 bytes from 192.168.100.147: icmp_seq=4 ttl=64 time=0.354 ms
64 bytes from 192.168.100.147: icmp_seq=5 ttl=64 time=0.548 ms
^C
— 192.168.100.147 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4055ms
rtt min/avg/max/mdev = 0.354/0.544/0.835/0.159 ms

```

Trên máy Kali, thực hiện Ping đến máy cài Snort


```

b22dc6164qb22dc6164-virtual-machine: $ sudo tail -f /var/log/snort/alert
03/03/12:26:14.126141 *** [1:1000001:1] B22DC6164-HoangAnhKhoa-Snort phát hiện có các gói Ping gửi đến. *** [Priority: 0] [ICMP] 192.168.100.3 -> 192.168.100.3
03/03/12:26:15.149300 *** [1:1000001:1] B22DC6164-HoangAnhKhoa-Snort phát hiện có các gói Ping gửi đến. *** [Priority: 0] [ICMP] 192.168.100.3 -> 192.168.100.3
147
03/03/12:26:16.150519 *** [1:1000001:1] B22DC6164-HoangAnhKhoa-Snort phát hiện có các gói Ping gửi đến. *** [Priority: 0] [ICMP] 192.168.100.3 -> 192.168.100.3
147
03/03/12:26:17.166046 *** [1:1000001:1] B22DC6164-HoangAnhKhoa-Snort phát hiện có các gói Ping gửi đến. *** [Priority: 0] [ICMP] 192.168.100.3 -> 192.168.100.3
147
03/03/12:26:28.742569 *** [1:1000002:1] B22DC6164-HoangAnhKhoa-Snort phát hiện có các gói tin ra quét trên cổng 80. *** [Priority: 0] [TCP] 192.168.100.3:4849
72 -> 192.168.100.147:80
03/03/12:26:41.748972 *** [1:1000002:1] B22DC6164-HoangAnhKhoa-Snort phát hiện có các gói tin ra quét trên cổng 80. *** [Priority: 0] [TCP] 192.168.100.3:508
50 -> 192.168.100.147:80
03/03/12:26:41.763610 *** [1:1421:11] SNMP AgentX tcp request *** [Classification: Attempted Information Leak] [Priority: 2] [TCP] 192.168.100.3:48426 -> 192.168.100.147:705
108.100.147:705
03/03/12:26:41.768629 *** [1:1418:11] SNMP request tcp *** [Classification: Attempted Information Leak] [Priority: 2] [TCP] 192.168.100.3:33974 -> 192.168.100.147:701
56
03/03/12:26:40.676324 *** [1:1000002:1] B22DC6164-HoangAnhKhoa-Snort phát hiện có các gói tin ra quét trên cổng 80. *** [Priority: 0] [TCP] 192.168.100.3:329
56 -> 192.168.100.147:80
03/03/12:27:53.682232 *** [1:1000002:1] B22DC6164-HoangAnhKhoa-Snort phát hiện có các gói tin ra quét trên cổng 80. *** [Priority: 0] [TCP] 192.168.100.3:596
Show Applications 3,147:80

```

Từ máy Kali, sử dụng công cụ hping3 để tấn công TCP SYN Flood máy Snort (dùng lệnh: `hping3 -c 15000 -d 120 -S -w 64 -p 80 --flood --rand-source 192.168.17.178`). Trên máy Snort kiểm tra kết quả phát hiện trên giao diện terminal hoặc log của Snort

Kiểm tra IP máy Snort

```
(kali@hoanganhkhhoa-b22dcat164)-[~]
$ sudo hping3 -c 15000 -d 120 -S -w 64 -p 80 --flood --rand-source 192.168.
100.147
HPING 192.168.100.147 (eth0 192.168.100.147): S set, 40 headers + 120 data by
tes
hping in flood mode, no replies will be shown
```

```
b22dcat164@b22dcat164-virtual-machine: ~
03/03-12:48:24.973954  [**] [1:1000003:0] B22DCAI164HoangAnhKhoa-Snort phat hien
dang bi tan cong TCP SYN Flood [**] [Priority: 0] {TCP} 159.52.78.83:25729 -> 1
92.168.100.147:80
03/03-12:48:24.973954  [**] [1:1000002:0] B22DCAT164HoangAnhKhoa-Snort phat hien
co cac goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 159.52.78.83:25729
-> 192.168.100.147:80
03/03-12:48:24.973964  [**] [1:1000003:0] B22DCAT164HoangAnhKhoa-Snort phat hien
dang bi tan cong TCP SYN Flood [**] [Priority: 0] {TCP} 184.77.134.102:25730 ->
192.168.100.147:80
03/03-12:48:24.973964  [**] [1:1000002:0] B22DCAT164HoangAnhKhoa-Snort phat hien
co cac goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 184.77.134.102:257
30 -> 192.168.100.147:80
03/03-12:48:24.973967  [**] [1:1000003:0] B22DCAT164HoangAnhKhoa-Snort phat hien
dang bi tan cong TCP SYN Flood [**] [Priority: 0] {TCP} 186.96.167.78:25731 ->
192.168.100.147:80
03/03-12:48:24.973967  [**] [1:1000002:0] B22DCAT164HoangAnhKhoa-Snort phat hien
co cac goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 186.96.167.78:2573
1 -> 192.168.100.147:80
03/03-12:48:24.974013  [**] [1:1000003:0] B22DCAT164HoangAnhKhoa-Snort phat hien
dang bi tan cong TCP SYN Flood [**] [Priority: 0] {TCP} 78.253.27.196:25732 ->
192.168.100.147:80
03/03-12:48:24.974013  [**] [1:1000002:0] B22DCAT164HoangAnhKhoa-Snort phat hien
co cac goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 78.253.27.196:2573
2 -> 192.168.100.147:80
```

Trên máy Snort hiện các thông báo

3. Kết luận

- Hệ thống phát hiện xâm nhập Snort hoạt động ổn định.
- Các luật mới được tạo và lưu vào trong file luật của Snort.
- Snort phát hiện thành công các rà quét tấn công kẻ trên.

4. Tài liệu tham khảo

- [1]. Chương 5, Giáo trình Cơ sở an toàn thông tin, Học viện Công nghệ BVCT, 2020. [2]. Suricata: <https://suricata.io/documentation/>
[3]. Snort: <https://www.snort.org/#documents>
[4]. OSSEC: <https://www.ossec.net/docs/>
[5]. Wazuh: <https://documentation.wazuh.com/current/index.html>